Nimbus Analytics Information Security Policy

Version 2.1, approved by the Chief Information Security Officer on 10 February 2025. This policy applies to all employees, contractors and interns of Nimbus Analytics.

1. Data Classification

All information is classified into one of four levels: Public, Internal, Confidential and Restricted. Customer data, credentials and encryption keys are always classified as Restricted. Restricted data must never be stored on personal devices or shared through personal email or messaging accounts.

2. Passwords and Authentication

Passwords for company accounts must be at least 14 characters long. Multi-factor authentication (MFA) is mandatory for every company system that supports it. All employees must store passwords in the company-provided 1Password vault. Passwords are not rotated on a fixed schedule; they must be changed immediately if a compromise is suspected.

3. Remote Access

Internal systems may only be accessed from outside an office through the company VPN, NimbusConnect. Public Wi-Fi networks, such as those in cafes, airports and hotels, may be used only while NimbusConnect is active. Screens must lock automatically after 5 minutes of inactivity.

4. Device Security

Full-disk encryption is mandatory on all laptops and mobile devices that access company data. Operating system security updates must be installed within 7 days of release.

Lost or stolen devices must be reported to the Security team within 4 hours of discovering the loss, by email to security@nimbusanalytics.example or through the 24/7 security hotline. The Security team will remotely lock and wipe the device. Delayed reporting is itself treated as a security incident.

5. Incident Response

Security incidents are classified by severity. A Severity 1 incident is a confirmed breach of customer data. For a Severity 1 incident an incident commander must be appointed within 30 minutes, and affected customers must be notified within 72 hours of the breach being confirmed. Regulators are notified as required by applicable law.

6. Access Management

Access rights to production systems are reviewed every quarter by system owners. When an employee leaves the company, all of their access must be revoked within 24 hours of their last working day.

7. Encryption

Data at rest is encrypted with AES-256. Data in transit must be protected with TLS 1.2 or higher.

8. Security Awareness

All employees complete security awareness training when they join and then once every year. Simulated phishing exercises are run every month.